

# CVE-2026-26050

CVSS v4: 8.4 [HIGH]

CVSS v3: 7.8 [HIGH]

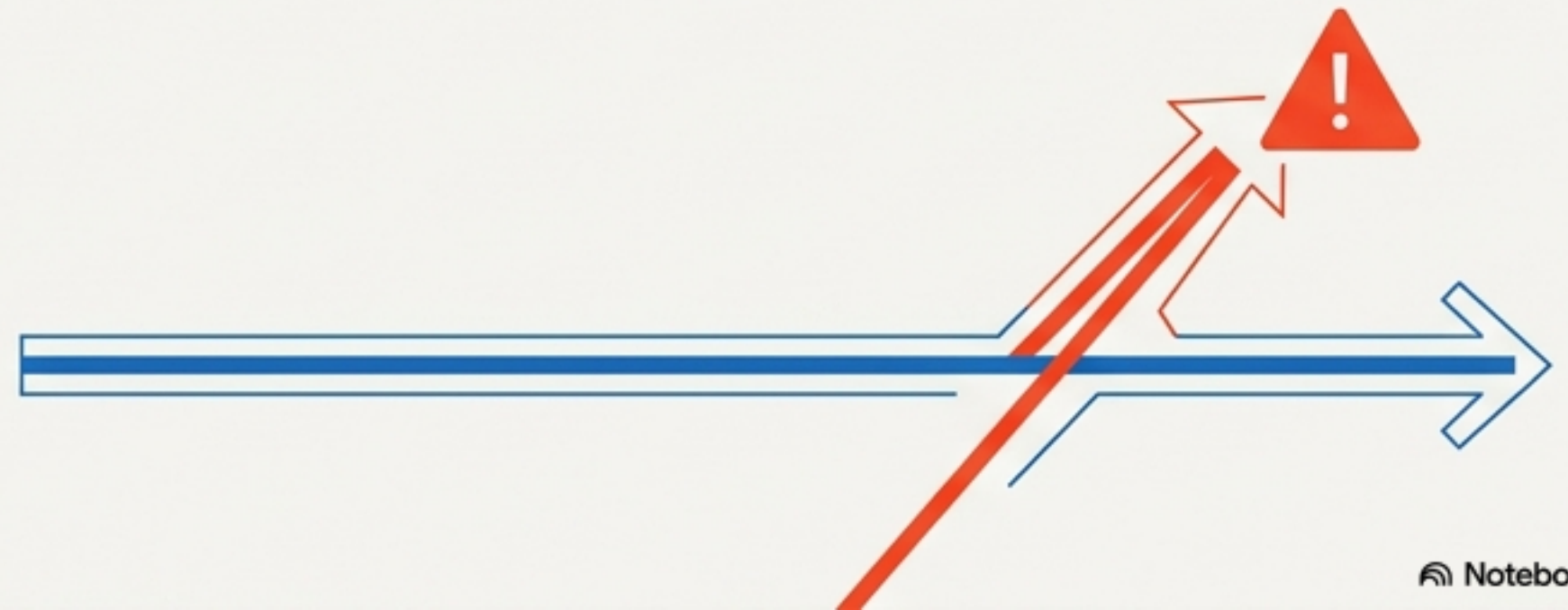
CWE-427

Uncontrolled Search  
Path Element

## Executive Briefing: Vulnerability Overview

The RICOH Job Log Analysis Tool  
(versions prior to 1.3.7) is vulnerable  
to DLL Search Order Hijacking.

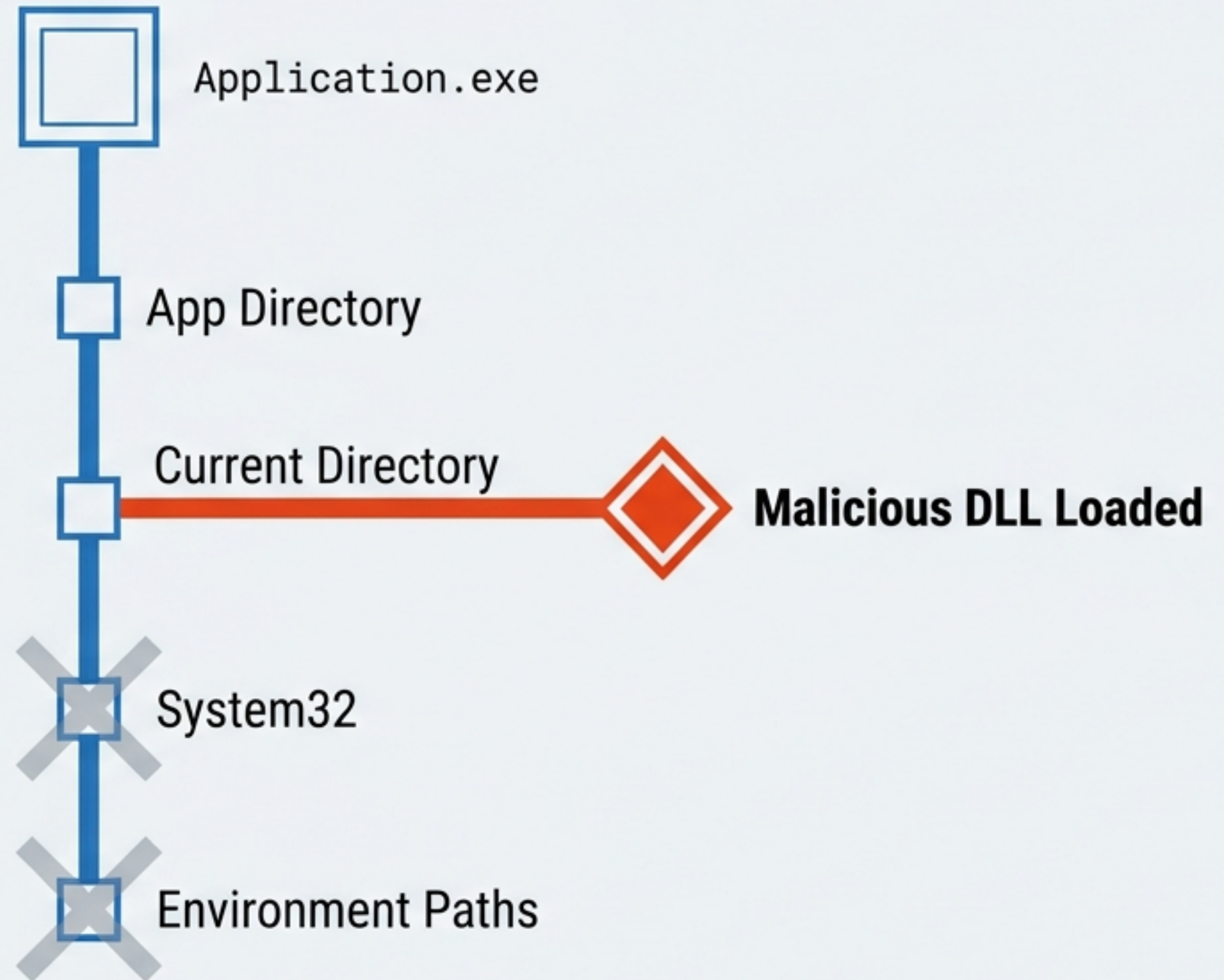
**Impact: Arbitrary Code Execution &  
Immediate Administrator Privilege  
Escalation.**





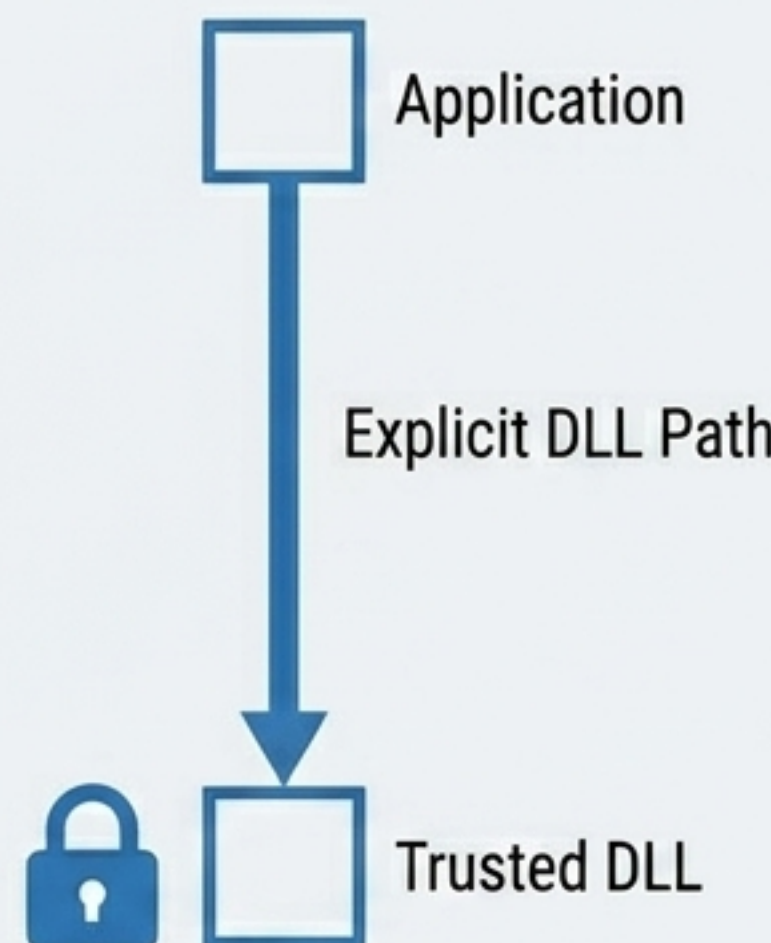
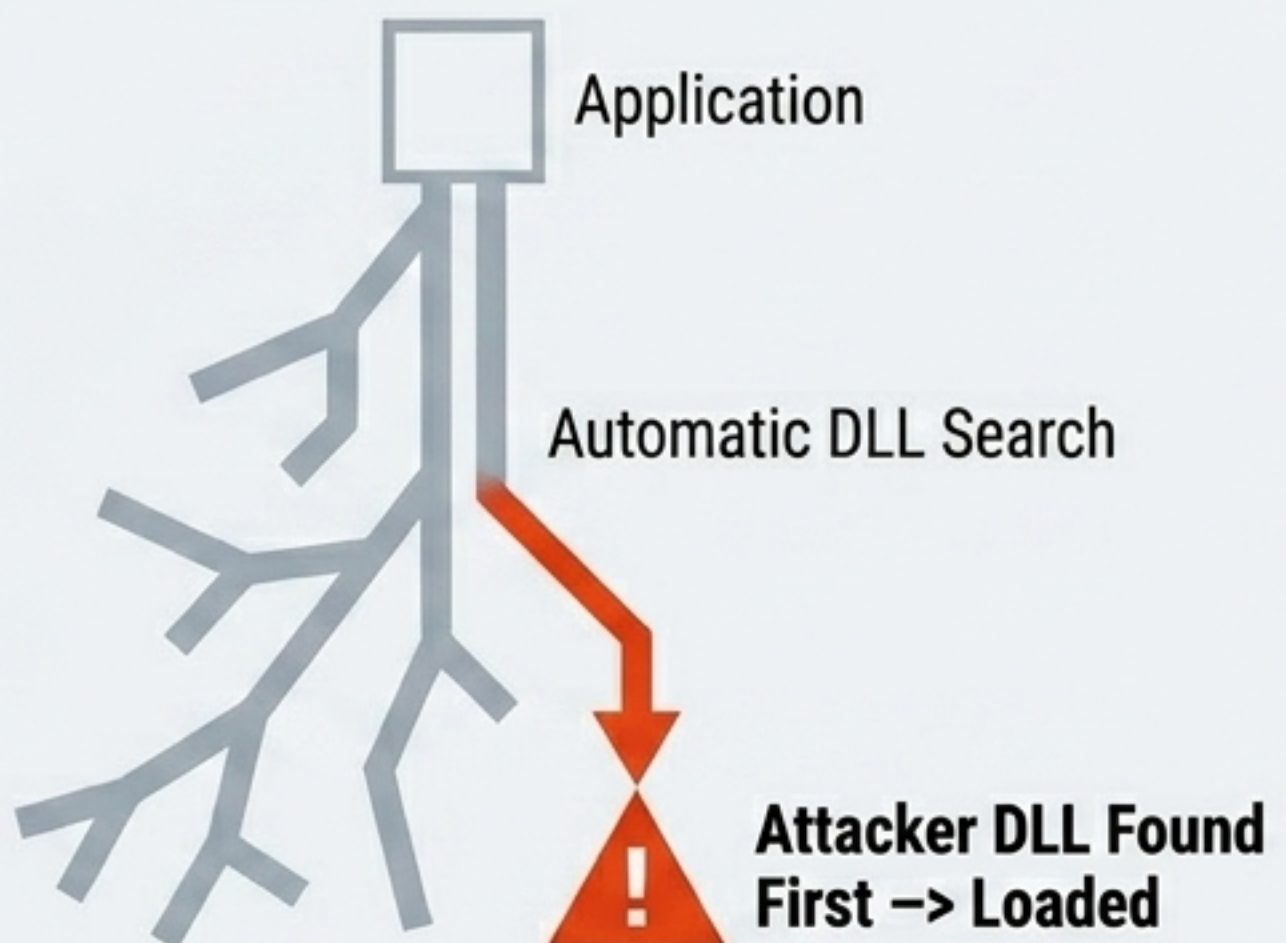
# Conceptual Primer: DLL Search Order Hijacking

- Because the application lacks explicitly specified trusted locations, Windows automatically searches a predefined hierarchy.
- Attackers exploit this heuristic search by planting malicious payloads higher in the execution sequence, intercepting the request.





# Root Cause Analysis: Architecture Comparison

| Secure Execution                                                                                                                                   | Vulnerable Execution (CWE-427)                                                                                                                                                          |
|----------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  <p>Application</p> <p>Explicit DLL Path</p> <p>Trusted DLL</p> |  <p>Application</p> <p>Automatic DLL Search</p> <p><b>Attacker DLL Found First -&gt; Loaded</b></p> |
| Direct, locked pipeline. No deviations allowed.                                                                                                    | Heuristic search path. Open funnel vulnerable to local interception.                                                                                                                    |

The Ricoh installer relies on heuristic searching, matching the flawed pattern of CWE-427: Uncontrolled Search Path Element.



# Threat Model: Attack Prerequisites

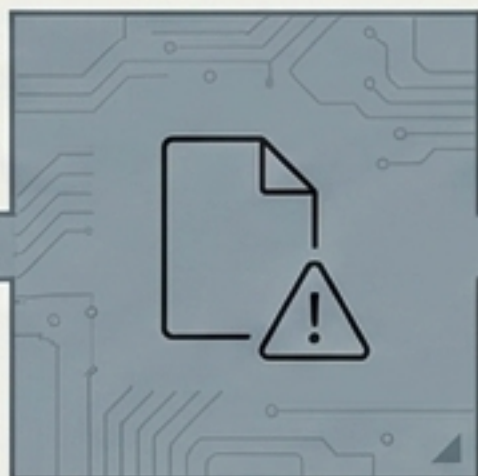
| Required Conditions                                                                                             | Not Required                                                                                                            |
|-----------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|
|  Local System Access           |  <del>Administrator Privileges</del> |
|  Ability to Place DLL in Path |  <del>Network Access</del>          |
|  Victim Executes Installer   |                                                                                                                         |

**Key Takeaway:** This vulnerability perfectly bridges the gap from low-privilege local access to full Administrator rights.



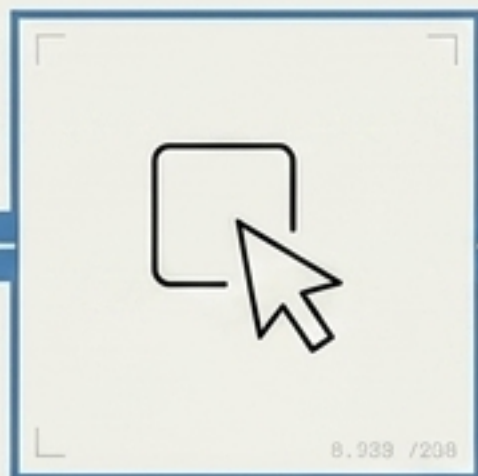
# The Exploitation Flow (Kill Chain)

**Step 1:**  
**Attacker:**  
Creates &  
Places DLL.

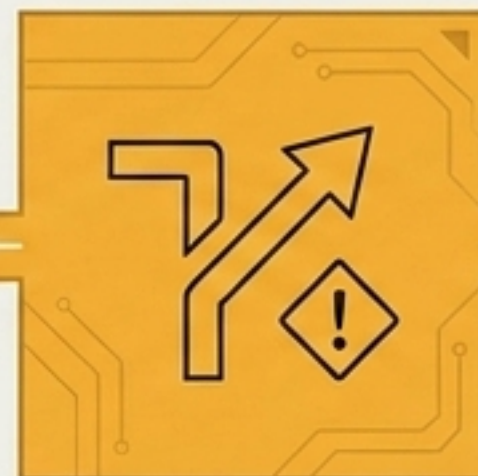


**Step 1: Setup  
(Attacker)**  
Creates & Places  
DLL.

**Step 3:**  
**Ricoh Hit**  
Voucher Branchant  
System.



**Step 2: Trigger  
(Victim)**  
Executes Ricoh  
Installer.



**Step 3: Intercept  
(System)**  
Installer  
Searches DLL.

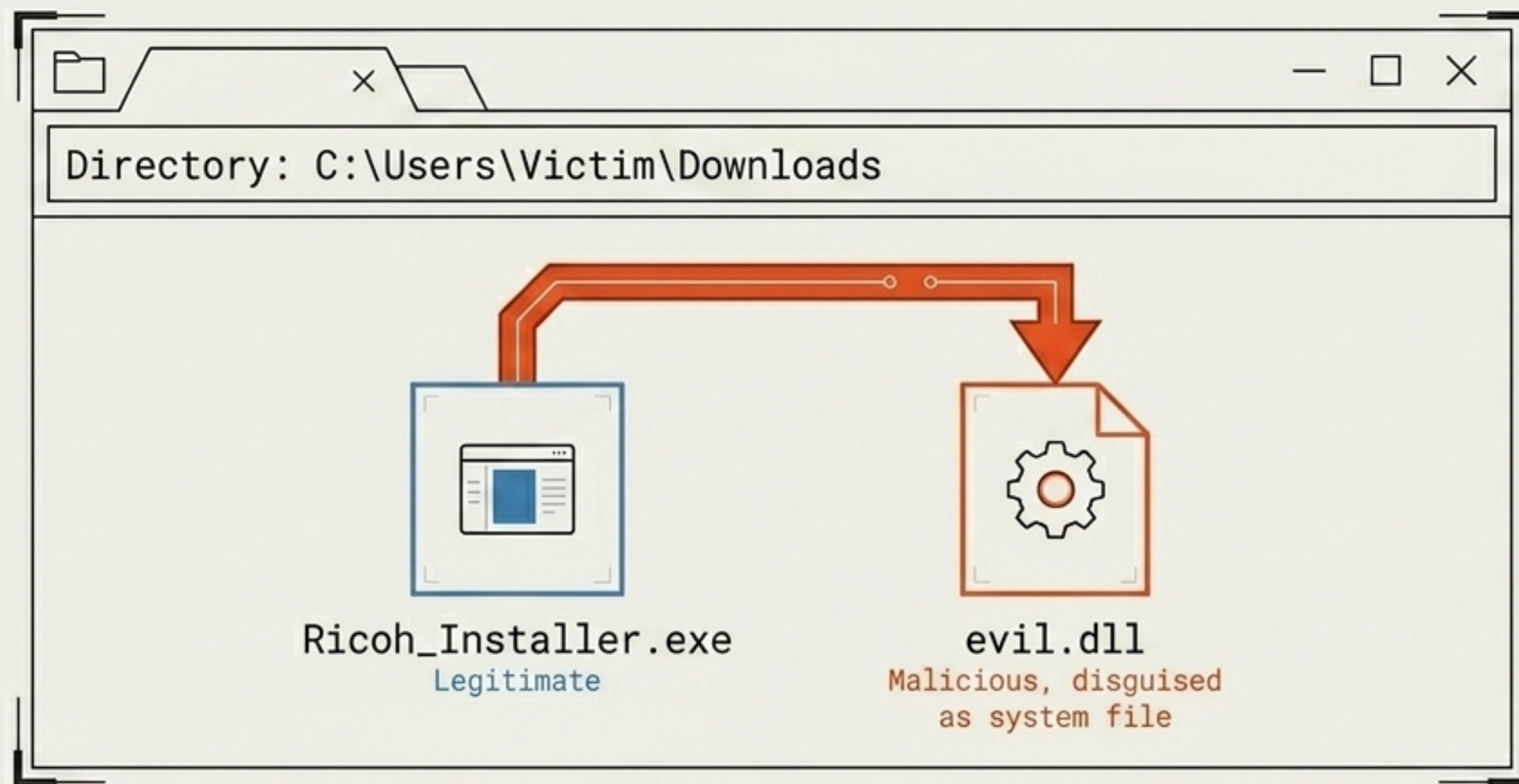


**Step 4: Execution  
(Impact)**  
Malicious DLL  
Loaded & Code  
Executes.

**OUTCOME:**  
Administrator  
Privileges  
Obtained



# Realistic Attack Scenario: The Downloads Trap



- Simply downloading the legitimate installer into a generic user directory stages the attack.
- If a payload is already present in that directory, running the installer triggers the uncontrolled search path, loading evil.dll instantly.



# Technical Impact & Blast Radius



Confidentiality: HIGH

[ Access Sensitive Data ]



Integrity: HIGH

[ Modify Files ] | [ Modify Settings ]



Availability: HIGH

[ Delete Data ] | [ Disable Services ]

**Total System Compromise:** Administrator-level code execution grants unrestricted, systemic control over the host environment.



# CVSS Severity Breakdown

|                                              |                                                                 |
|----------------------------------------------|-----------------------------------------------------------------|
| CVSS v3 Score: 7.8                           | CVSS v4 Score: 8.4                                              |
| CVSS:3.0/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H | CVSS:4.0/AV:L/AC:L/AT:N/PR:N/UI:A/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N |

| Translation Key                                  |
|--------------------------------------------------|
| <b>AV:L</b> -> Local Access                      |
| <b>AC:L</b> -> Easy Complexity                   |
| <b>PR:N</b> -> No Privileges Required            |
| <b>UI:R/A</b> -> User Execution Required         |
| <b>C/I/A:H</b> -> High Impact across all vectors |



# MITRE ATT&CK Matrix Mapping

[648, 33 Δ]

T1574

Hijack Execution  
Flow

**T1574.001**

DLL Search Order  
Hijacking

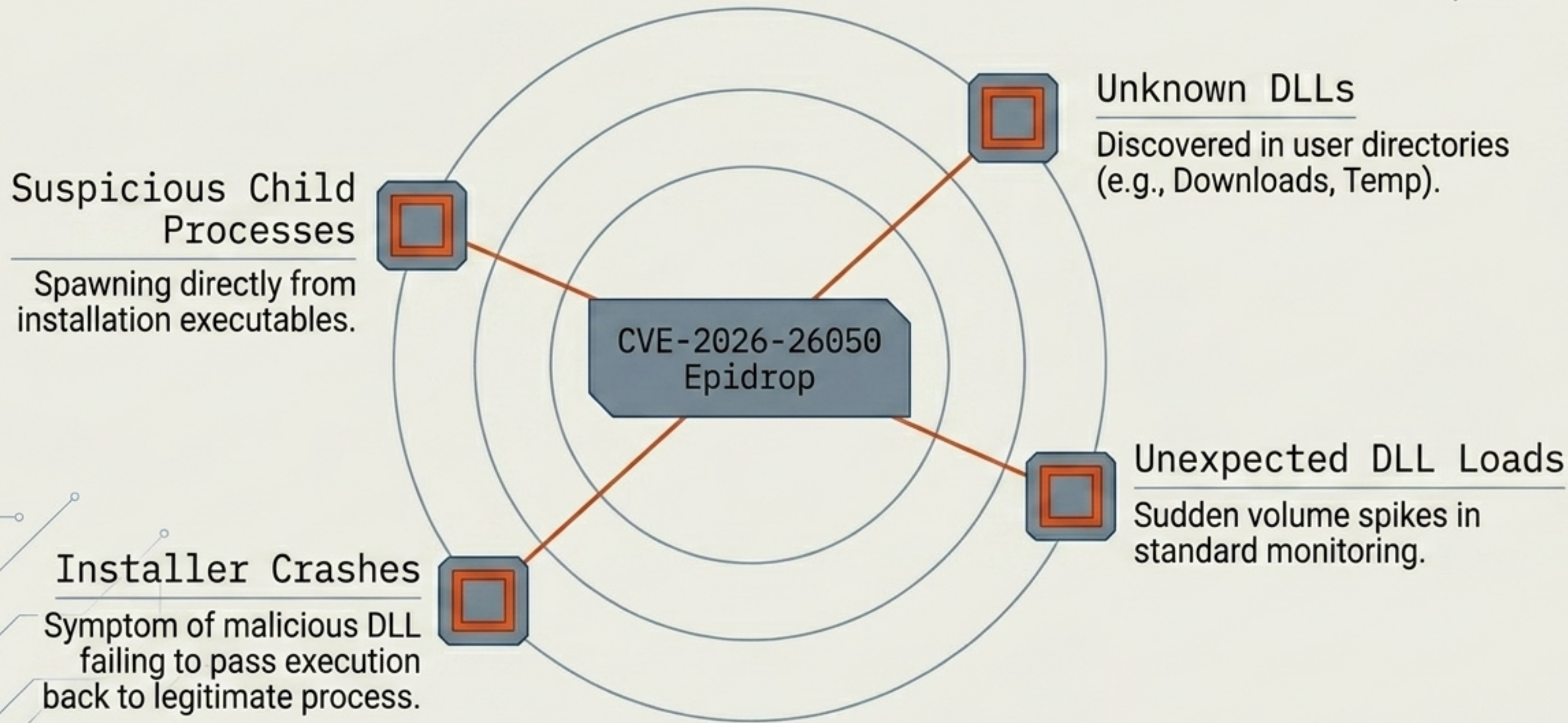
T1204

User  
Execution

Mapping to standard threat hunting frameworks enables SOC teams to correctly categorize and build detections for uncontrolled path exploits.



# Indicators of Compromise (IoCs) & Telemetry





# Active Detection Opportunities



## EDR Rules

Flag installers executing and loading DLLs directly from C:\Users\\* directories.



## Sysmon

Alert on Event ID 7 (Image Loaded) specifically for unsigned DLLs masking as system files.



## Windows Event Logs

Track anomalous path executions and unexpected directory traversal.



# Remediation & Mitigation Playbook

## Immediate Vendor Fix

### Update to Version 1.3.7+

Ricoh Company Ltd. has patched the improper path handling in all subsequent versions.

## Defense in Depth Controls



Enable Safe DLL  
Search Mode



Enforce Application  
Whitelisting



Mandate Code Signing  
Verification



Restrict User Write  
Access in execution  
directories



# Trust Requires Explicitness.

CVE-2026-26050 is a symptom of a larger architectural flaw. In secure environments, software cannot rely on heuristic searches. Execution paths must be explicit, verified, and strictly controlled to prevent high-severity privilege escalation.